

Manual 50 — Global AI Governance Crosswalk

Publication source: controlled English edition

Currentness baseline: 1 September 2026

Purpose

This manual provides a practical crosswalk across the EU AI Act, ISO/IEC 42001, NIST AI RMF 1.0 and AI 600-1, Singapore AI-governance frameworks and AI Verify, the OECD AI Principles, and the repository's Universal AI Governance Foundation. It is designed for implementation, audit preparation, evidence reuse, training, and executive governance. It does not claim that different regimes are legally or technically equivalent.

Core rule: harmonize controls, never erase source differences

A common enterprise control may support several regimes, but each source retains its own scope, legal status, actor definitions, thresholds, assurance method, documentation expectations, and evidence requirements. Binding law controls legal mapping. Voluntary standards and frameworks remain voluntary unless incorporated into law, contract, or an internal commitment. ISO certification, EU conformity assessment, AI Verify testing, NIST-aligned TEVV, and internal audit are distinct assurance mechanisms.

Relationship taxonomy

- ****Direct:**** materially addresses the same control objective at the relevant level.
- ****Partial:**** addresses only part of the objective; additional evidence is required.
- ****Supporting:**** helps enable the objective but is not sufficient by itself.
- ****Contextual:**** informs governance intent or principles without creating the same requirement.
- ****None / N/A:**** no defensible relationship exists for the assessed scope.

A blank or qualified mapping is preferable to unsupported equivalence.

Twenty common control objectives

GC-01 Governance and accountability

Establish accountable ownership, decision rights, policy, escalation, exceptions, and management oversight. Typical evidence includes governance charters, RACI matrices, policy approvals, committee decisions, and management reporting.

GC-02 AI inventory and ownership

Maintain a current inventory of AI systems and use cases including owner, purpose, model/provider, lifecycle state, geography, data sensitivity, dependencies, and risk tier.

GC-03 Role and value-chain responsibility

Determine who designs, provides, deploys, imports, distributes, integrates, operates, or materially changes AI. Preserve EU AI Act legal actor definitions rather than replacing them with generic enterprise labels.

GC-04 Risk classification and tiering

Apply the classification method required by the relevant source while maintaining an internal enterprise tier for governance depth. EU legal risk classification, internal tiering, NIST contextual assessment, and Singapore governance assessment are not interchangeable.

GC-05 Risk and impact assessment

Identify purpose, context, affected parties, benefits, harms, foreseeable misuse, dependencies, existing controls, residual risk, and accountable disposition before deployment and after material change.

GC-06 Data governance and privacy

Govern provenance, quality, rights, access, minimization, lineage, retention, sensitive data, RAG sources, and data-related risks. Privacy-law bases and rights remain source-specific.

GC-07 Security, robustness, and resilience

Protect models, applications, infrastructure, agents, data, tools, and dependencies against threats, failures, misuse, and supply-chain compromise. Define recovery and containment expectations proportional to risk.

GC-08 Transparency and communication

Provide accurate information about AI use, capabilities, limitations, material outputs, and responsibilities to the appropriate audience. Legal disclosure duties remain source-specific.

GC-09 Human oversight and intervention

Ensure people have competence, authority, information, and practical means to intervene at meaningful decision or action points. Preserve approval, override, rejection, and escalation evidence.

GC-10 Testing, evaluation, verification, and validation

Define claims and acceptance criteria; test performance, safety, security, privacy, robustness, and control effectiveness with reproducible evidence proportional to risk.

GC-11 Documentation and recordkeeping

Maintain current technical and governance records describing design, versions, decisions, controls, evaluations, approvals, incidents, and material changes.

GC-12 Deployment and approval gates

Require an accountable disposition before production or material capability expansion: approve, conditionally approve, restrict, remediate, suspend, or reject.

GC-13 Third-party and supply-chain governance

Assess providers, models, tools, APIs, data processors, hosting, and agent dependencies. Address data handling, security, change notification, incident obligations, continuity, concentration risk, and exit.

GC-14 Monitoring and continuous assurance

Monitor performance, drift, risk indicators, policy denials, complaints, incidents, provider changes, model changes, open findings, and control effectiveness after deployment.

GC-15 Incident management

Detect, contain, investigate, preserve evidence, remediate, and escalate AI incidents. External notification thresholds and timelines remain jurisdiction-specific.

GC-16 Change management and revalidation

Treat changes in model/provider, data/RAG, purpose, affected population, tools/APIs, autonomy, permissions, geography, or safety/security controls as potential revalidation triggers.

GC-17 Audit and independent assurance

Provide independent challenge proportional to materiality and preserve findings, management responses, remediation evidence, and closure decisions.

GC-18 AI literacy and competence

Ensure governance, development, deployment, oversight, security, procurement, legal, audit, and operations personnel have competence appropriate to their responsibilities.

GC-19 Continuous improvement

Use monitoring, incidents, testing, audit, stakeholder feedback, regulatory change, and provider change to improve controls and governance.

GC-20 Agent identity, autonomy, permissions, and action provenance

Assign attributable identities, bound autonomy, enforce least privilege, restrict tools and data, require significant human checkpoints where appropriate, preserve action provenance, monitor behavior, and maintain containment controls.

Source-family relationship guide

EU AI Act

Treat the Act as binding law within its scope. Preserve legal actor roles, system categories, prohibited practices, application dates, transparency duties, high-risk obligations, GPAI obligations, conformity requirements, registration, post-market monitoring, incident reporting, and enforcement provisions where applicable. A generic enterprise control is supporting evidence unless the exact legal requirement and scope are also demonstrated.

ISO/IEC 42001

Treat ISO/IEC 42001 as an AI management-system standard. Crosswalk at a high level using independently authored management-system and control objectives; do not reproduce protected standard text. Alignment is not certification, and certification is not a substitute for legal compliance.

NIST AI RMF 1.0 and AI 600-1

Map enterprise controls to GOVERN, MAP, MEASURE, and MANAGE relationships and to GenAI-specific risk actions where appropriate. NIST remains voluntary guidance and should not be represented as law or certification.

Singapore governance and AI Verify

Use the Model AI Governance Framework family, GenAI governance guidance, AI Verify testing, and agentic-AI governance guidance as practical governance and assurance references. AI Verify testing is not automatic certification or proof of compliance with another jurisdiction.

OECD AI Principles

Use the OECD principles as an intergovernmental policy baseline for inclusive growth and well-being, human rights and democratic values, transparency and explainability, robustness/security/safety, and accountability. They provide strong governance context but are not a substitute for jurisdiction-specific law.

Evidence harmonization register

The minimum reusable evidence set should include:

- EV-01 AI inventory record;
- EV-02 governance charter and RACI;
- EV-03 risk/impact assessment;
- EV-04 data and RAG lineage record;
- EV-05 security architecture and threat model;
- EV-06 transparency/communication artifact;
- EV-07 human-oversight design and intervention logs;
- EV-08 TEVV/validation package;
- EV-09 deployment approval;
- EV-10 third-party assessment;
- EV-11 monitoring dashboard/report;
- EV-12 incident record;
- EV-13 change/revalidation record;
- EV-14 audit or independent review;
- EV-15 competence/training record;
- EV-16 improvement backlog;
- EV-17 agent-action provenance.

For every reused evidence item record: evidence → originating control → target source relationship → sufficiency and limitations → additional source-specific evidence → accountable owner → date/version.

Practical crosswalk scenarios

Scenario 1 — Enterprise GenAI assistant

A company deploys a GenAI assistant using a third-party model and internal RAG. The common-control baseline requires inventory, provider assessment, data/RAG lineage, risk assessment, security architecture, testing, transparency, approval, monitoring, and incident handling. The EU analysis additionally determines legal role and applicable AI Act duties. NIST AI 600-1 strengthens GenAI-specific risk analysis. Singapore guidance supports practical lifecycle governance and testing. ISO/IEC 42001 supports the management-system layer. OECD principles inform accountability, transparency, and robustness objectives.

Scenario 2 — AI-supported hiring

A hiring model requires explicit legal and human-rights analysis, bias/fairness evaluation, human oversight, documentation, monitoring, appeals/escalation, and change control. A shared enterprise assessment may be reusable, but EU legal classification and any local employment/privacy obligations require separate scope analysis.

Scenario 3 — Agentic workflow with tool access

An agent can create tickets, query internal data, and trigger external actions. Add agent identity, least privilege, tool allowlists, action limits, approval checkpoints, provenance logs, kill/containment mechanisms, and misuse testing. Singapore agentic guidance and security guidance may be direct or supporting; EU/ISO/NIST relationships depend on exact scope.

Scenario 4 — Provider model change

A provider silently changes model version or behavior. The organization detects the change through supplier monitoring, evaluates materiality, reruns relevant tests, updates risk and transparency records, and issues a new deployment decision where required.

Scenario 5 — Multi-regime assurance

A single TEVV package may support NIST, Singapore testing, internal audit, ISO management-system evidence, and selected legal controls, but only after documenting relationship type, scope, sufficiency, limitations, and additional source-specific evidence. Never convert this into a universal compliance percentage.

Scenario 6 — Executive reporting

Executive dashboards should report systems by risk tier and jurisdiction, unresolved high-priority findings, incidents, material provider/model changes, overdue approvals, assurance status, and evidence freshness. Avoid a single blended “percent compliant” score across unlike regimes.

Gap-analysis method

For each common control:

1. identify the implemented enterprise control;
2. determine applicable sources and exact scope;
3. assign a relationship type;
4. identify missing source-specific actor, threshold, process, documentation, evidence, or assurance requirements;
5. classify the gap as control, evidence, legal interpretation, process, assurance, or competence;
6. prioritize as P1 critical, P2 significant, or P3 improvement;
7. assign owner and remediation date;
8. retest and update mapping rationale.

Quality and anti-false-equivalence rules

Do not publish universal compliance percentages across unlike regimes. Do not claim that ISO certification proves EU AI Act compliance. Do not claim that NIST adoption equals legal compliance. Do not claim that AI Verify testing equals certification in another regime. Do not

reproduce copyrighted ISO clause text. Preserve uncertainty explicitly and obtain qualified legal interpretation when a legal conclusion is required.

Implementation sequence

Use the crosswalk operationally in this order: inventory and scope → source applicability → common controls → source-specific delta analysis → evidence sufficiency → remediation → testing/assurance → accountable approval → monitoring → periodic currentness refresh.

Currentness control

Before each controlled release, revalidate the EU AI Act legal baseline, ISO/IEC 42001 edition/status, NIST AI RMF and AI 600-1 status, current Singapore framework versions, and OECD AI Principles status. Record the verification date and preserve links or source identifiers in the source map.

Completion criterion

This manual is complete when every crosswalk conclusion is traceable to a source family, relationship type, common objective, reusable evidence class, difference note, and source-specific delta. The objective is defensible governance reuse—not artificial equivalence.